



ADNAN SHAMIM

Agent AI Leader |
Internal Audit & AI Governance Professional



EMAIL
ad.shamim1985@gmail.com



MOBILE
+92 313 8224669



CREATOR OF
**THE FUTURIST'S
STRATEGY CONE™**
& **THE I-A-N-E-T-F™**
FRAMEWORK™

— CREATOR OF —
**THE FUTURIST'S
STRATEGY CONE™**

&
THE I-A-N-E-T-F™
FRAMEWORK

Auditing Agent AI —
Enterprise Audit & Assurance Framework

FRAMEWORK THESIS
DECLARED GOVERNANCE ≠
ENFORCED GOVERNANCE.

4 STAGES OF ASSURANCE



RISK

Identify, assess
and prioritize
AI risks.



AUDIT

Design and perform
intelligent audits
with AI oversight
and human
judgment.



EVIDENCE

Capture
immutable,
traceable and
verifiable audit
evidence.



REPORTING

Deliver meaningful
insights for
assurance and
decision-making.



**HUMAN AT THE
RIGHT BOUNDARY**
AI Works.
Humans Decide.



**EVIDENCE AT
EVERY STEP**
If it's not recorded,
it didn't happen.



**ASSURANCE
THAT MATTERS**
From Declaration
to Demonstration.

THE I-A-N-E-T-F FRAMEWORK™

Auditing Agent AI — Enterprise Audit & Assurance Framework



Designed for Boards,
CFOs & CAEs to Govern
Agent AI with Confidence



AI Enhances Capability.
**Humans Maintain
Accountability.**



Explore the
Framework
**Scan to
learn more.**

INDEPENDENT THINKING. OBJECTIVE ASSURANCE. ACCOUNTABLE AI.



ad.shamim1985@gmail.com



+92 313 8224669



linkedin.com/in/
adnan-shamim-802a6622b



DM **"CONE"** for Framework

THE I-A-N-E-T-F FRAMEWORK™

Auditing Agentic AI – Enterprise Audit & Assurance Framework

FRAMEWORK THESIS

Declared governance ≠ enforced governance.

Agentic AI should not be audited merely by asking:

-  Is there an AI policy?
-  Was the agent approved?
-  Is there a human in the loop?
-  Are logs available?
-  Has testing been performed?

The fundamental audit question is:

Can management demonstrate, through sufficient, reliable, relevant, and useful evidence, that the agent operates within its approved purpose, authority, risk tolerance, decision boundaries, and control environment—and that those controls are appropriately designed, implemented, enforced where required, operating effectively, monitored, change-controlled, and capable of timely intervention throughout the agent's lifecycle?

For higher-risk systems, the assessment must additionally consider:

- multi-agent interactions;
- third-party dependencies;
- autonomous tool use;
- material delegation;
- behavioral drift;
- self-modification or self-evolution;
- cumulative exposure;
- degraded operating conditions;
- and decommissioning.

THE SIX PILLARS

Pillar	Core Audit Question
I – INTENT	What is the agent authorized and prohibited to do, and are those boundaries explicit and testable?
A – AUTHORITY	Who or what authorizes each material action, and can that authority be verified at the point of execution?
N – ENFORCEMENT	Where prevention is required, can the system technically prevent violations under realistic operating conditions?
E – TESTING	Are the agent and its controls continuously and adversarially tested against relevant failure modes, including multi-agent behavior and material behavioral change?
T – TRACEABILITY & EVIDENCE	Can material actions and decisions be independently reconstructed from authorization through outcome using trustworthy evidence?
F – FORENSICS & REVOCABILITY	Can the organization detect, stop, contain, revoke, recover, notify, and reconstruct when the agent behaves unexpectedly?

I – INTENT

Bounded, Codified & Verifiable

Principle

**Unbounded intent creates unauditible risk.
Ambiguous intent creates unenforceable
boundaries.**

The agent's authorized purpose must be translated into explicit, testable control objectives.

Mandatory Requirements

1. Purpose

The purpose must be:

- human-readable;
- machine-interpretable where technically appropriate;
- unambiguous;
- linked to approved business objectives.

2. Prohibited actions

Material prohibited actions must be explicitly identified.

Unspecified actions must not automatically receive authority where the risk requires explicit authorization.

3. Decision boundaries

Define, as applicable:

- transaction limits;
- aggregate exposure;
- time limits;
- jurisdictions;
- counterparties;
- systems;
- tools;
- data;
- decision classes;
- escalation requirements.

4. Risk tolerance

Material risk thresholds must be quantified where practical.

Examples include:

- maximum loss;
- maximum exposure;
- maximum transaction value;
- maximum aggregate exposure;
- error tolerance;
- privacy exposure;
- regulatory exposure.

5. Materiality

Define materiality by action class and establish aggregate thresholds where individual actions could combine into material exposure.

6. Escalation triggers

Triggers must be objective and testable.

Example:

Confidence below the approved threshold → human review required.

7. Data boundaries

Define:

- permitted data;
- prohibited data;
- conditional data;
- required conditions for use.

8. Semantic mapping

Each material intent statement must map to one or more control mechanisms.

The mapping must be reviewed for:

- completeness;
- consistency;
- necessity;
- enforceability.

9. Time boundaries

Where applicable:

- operating hours;
- session duration;
- action frequency;
- cooldown periods.

10. Geographic boundaries

Define permitted jurisdictions and cross-border restrictions.

10. Geographic boundaries

Define permitted jurisdictions and cross-border restrictions.

11. Counterparty boundaries

Define:

- permitted;
- prohibited;
- conditional counterparties.

12. Version control

Intent versions must be:

- uniquely identified;
- timestamped;
- protected against unauthorized alteration;
- linked to the deployed configuration.

13. Deployment integrity

Where technically appropriate, the deployed configuration must be verifiably associated with the approved version.

14. Formal assurance

Where system criticality warrants it, formal methods, bounded model checking, runtime verification, or equivalent assurance techniques should be applied within a clearly defined scope.

15. Intent change control

Material changes require:

change assessment → approval → testing →
deployment verification → monitoring.

Emergency changes require enhanced authorization and retrospective review.

INTENT LOOPHOLE TESTS

The auditor should test for:

- implicit permissions;
- aggregate transaction splitting;
- semantic ambiguity;
- unauthorized configuration drift;
- approved-versus-deployed mismatch;
- unapproved intent changes;
- time-boundary bypass;
- jurisdiction bypass;
- counterparty bypass;
- incomplete formal-assurance scope.

Failure Indicators

A significant deficiency exists where:

- material intent cannot be translated into testable control objectives;
- material boundaries rely solely on subjective interpretation;
- aggregate exposure can bypass controls;
- deployed configuration materially differs from approved configuration;
- unauthorized intent changes can occur without detection;
- formal assurance claims exceed the actual scope tested.

A – AUTHORITY

Zero-Trust, Verifiable & Revocable

Principle

Authority must be attributable, bounded, time-limited, context-aware, and revocable.

Cryptographic mechanisms should be used where materiality and architecture warrant them.

Mandatory Requirements

1. Action authorization

Material actions must have attributable authorization containing, where applicable:

- actor;
- action class;
- scope;
- time validity;
- value limit;
- aggregate limit;
- jurisdiction;
- data classification;
- revocation status;
- unique transaction identifier.

2. Secure credential management

Material authority credentials must be protected using appropriately hardened mechanisms.

3. Policy-controlled authorization

Authorization mechanisms must evaluate applicable policy before material execution.

4. Delegation

Delegation must be:

- explicit;
- bounded;
- traceable;
- time-limited;
- subject to original constraints.

5. Segregation of duties

Material incompatible functions must not be combinable by a single uncontrolled actor or process.

6. Override

Material overrides require:

- authorized personnel;
- appropriate authentication;
- documented justification;
- logging;
- retrospective review.

7. Revocation

Authority must be capable of timely revocation appropriate to the risk.

8. Expiration

Standing authority should be minimized.
Credentials and tokens must have defined lifetimes appropriate to risk.

9. Replay protection

Where signed transactions are used, unique transaction identifiers or equivalent mechanisms must prevent unauthorized replay.

10. Contextual authority

Authorization should account for relevant context such as:

- jurisdiction;
- data classification;
- time;
- action type;
- transaction value.

11. Emergency access

Break-glass access must be:

- exceptional;
- authorized;
- logged;
- monitored;
- retrospectively reviewed.

12. Decommissioning

Decommissioned agents must lose authority through controlled credential/token expiry or revocation.

AUTHORITY TESTS

The auditor should be able to establish:

1. Who authorized the action?
2. What exactly was authorized?
3. When was it authorized?
4. What constraints applied?
5. Was the authority valid at execution?
6. Was delegation legitimate?
7. Could the authority be revoked?
8. Were unauthorized requests rejected?
9. Were emergency overrides controlled?
10. Did decommissioned agents retain access?

Failure Indicators

Authority is deficient where:

- material actions cannot be attributed;
- authority has no meaningful boundary;
- expired authority remains usable;
- unauthorized delegation is possible;
- revocation cannot occur within the risk-required timeframe;
- emergency access is effectively permanent;
- decommissioned agents retain material authority.

N – ENFORCEMENT

Preventive, Production-Verified & Blast-Radius Controlled

Principle

Detection after an unacceptable action is not equivalent to prevention.

Where prevention is required by the risk, the control must operate at or sufficiently close to the execution point to prevent the prohibited outcome.

Mandatory Requirements

1. Preventive controls

Material preventive risks require technical preventive mechanisms where reasonably achievable.

2. Production verification

Controls must be tested in representative operating conditions.

Production testing must be carefully designed to avoid unacceptable operational impact.

3. Continuous control monitoring

Material preventive mechanisms require ongoing health monitoring.

4. Bypass detection

Bypass attempts must be:

- recorded;
- investigated;
- risk-assessed;
- contained where necessary.

5. Privilege control

Administrative privileges must not create uncontrolled bypass paths.

6. Agent-to-agent delegation

Delegation must preserve:

- original authority;
- original restrictions;
- accountability;
- aggregate exposure limits.

7. Human approval

Human approval is preventive only when:

- approval occurs before execution;
- approval is deliberate;
- the system technically requires it;
- the approval is attributable;
- appropriate information is provided;
- workload is manageable.

8. Aggregate enforcement

Controls must address cumulative exposure where multiple individually acceptable actions could create material risk.

9. Fail-safe behavior

Where a control cannot evaluate a material action, the system must follow the approved safe-state behavior.

For high-risk actions, this may require denial rather than execution.

10. Circuit breakers

Material agents require appropriately designed automatic containment mechanisms.

11. Rate limits

Limits should be applied where runaway activity could create material exposure.

12. Tool and data boundaries

Unapproved tools and data sources must not be accessible to the agent where access creates material risk.

13. Network segmentation

Agents must operate within appropriately restricted technical environments.

14. Input validation

Inputs must be validated according to risk.

15. Defense in depth

Material controls should not depend upon a single enforcement layer.

BLAST-RADIUS CONTROL

Every material agent should have a documented maximum foreseeable exposure across relevant dimensions:

- actions per time period;
- transaction value;
- aggregate value;
- systems accessible;
- data accessible;
- geographic reach;
- delegation depth;
- maximum financial exposure;
- maximum data exposure;
- reversibility;
- containment time.

The exact thresholds must be **risk-based and formally approved**, rather than arbitrary universal numbers.

E — TESTING

Continuous, Adversarial & Adaptive

Principle

Testing is not a calendar event. It is an assurance capability.

Testing must evolve as the system, environment and threat landscape evolve.

Testing Domains

Pre-deployment

Full regression testing before material deployment.

Continuous monitoring

Monitor:

- behavioral changes;
- control health;
- anomaly patterns;
- configuration changes.

Adversarial testing

Test relevant:

- prompt manipulation;
- instruction conflicts;
- context manipulation;
- tool misuse;
- authorization bypass;
- data poisoning;
- malicious inputs.

Human oversight testing

Test:

- unavailable reviewers;
- delayed responses;
- incorrect approvals;
- excessive workload;
- approval fatigue.

Multi-agent testing

Test:

- delegation;
- conflicting objectives;
- authority propagation;
- emergent behavior;
- coordinated policy violations.

Control degradation

Test failures involving:

- network;
- authentication;
- logging;
- monitoring;
- policy services;
- data services;
- critical infrastructure.

Behavioral change

Material behavioral drift must trigger investigation and, where appropriate:

containment → assessment → re-testing → re-approval.

RE-TESTING TRIGGERS

Re-testing should occur following:

- material intent changes;
- authority changes;
- tool changes;
- model changes;
- material configuration changes;
- training-data changes;
- self-modification;
- significant behavioral drift;
- incidents;
- near misses;
- relevant new vulnerabilities;
- significant threat intelligence;
- regulatory changes;
- material environmental changes.

The response timeframe must be proportionate to risk and documented in advance.

T – TRACEABILITY & EVIDENCE

Forensic-Grade, Tamper-Evident & Reconstructable

Principle

A log is not automatically evidence. Evidence must be trustworthy, relevant, complete, timely and reconstructable.

Mandatory Requirements

1. Tamper resistance

Material records must be protected against unauthorized alteration or deletion.

2. Independent replication

Critical evidence should be replicated or otherwise protected against single-system failure.

3. Integrity verification

Cryptographic integrity mechanisms should be used where appropriate.

4. Material action record

A material action should capture, as applicable:

1. who;
2. what;
3. when;
4. why;
5. authority;
6. outcome.

5. Decision rationale

For material decisions, retain an appropriate **decision rationale**, including:

- relevant factors;
- applicable policy;
- significant alternatives considered;
- reason for escalation or approval.

The framework does **not** require disclosure or storage of private model chain-of-thought.

6. Context capture

Capture relevant:

- agent state;
- configuration;
- tools;
- data;
- environment;
- policy version.

7. Version linkage

Material records should identify relevant:

- model/version;
- policy;
- configuration;
- tool;
- agent version.

8. Data provenance

Material decisions should be traceable to relevant data sources and appropriate integrity/freshness controls.

9. Retention

Retention must meet applicable requirements and documented business/risk needs.

10. Decommissioning evidence

Decommissioning must preserve appropriate records and establish termination of authority.

11. Auditor access

Internal Audit must have appropriate direct access to evidence necessary to discharge its responsibilities, subject to legitimate confidentiality and access controls.

12. Chain of custody

Critical records must maintain sufficient integrity metadata to establish provenance and detect unauthorized alteration.

13. Encryption

Sensitive records must be appropriately protected in transit and at rest.

14. Privacy

Evidence collection must minimize unnecessary sensitive information and enforce appropriate access controls and redaction.

EVIDENCE QUALITY TEST

The auditor assesses:

Sufficiency

Is enough evidence available?

Reliability

Can the evidence be trusted?

Relevance

Does it address the control objective?

Usefulness

Can an independent reviewer understand it?

Timeliness

Was it captured close to the event?

Completeness

Are material gaps identifiable?

Integrity

Can unauthorized alteration be detected?

Privacy

Is sensitive information appropriately protected?

F – FORENSICS & REVOCABILITY

Intervention-Ready & Degraded-Condition Verified

Principle

The organization must assume that a material agent can eventually behave incorrectly—and demonstrate that it can contain the consequences.

Six Capabilities

Capability	Required Outcome
STOP	Rapidly suspend the agent
CONTAIN	Restrict tools, systems, data and network access
REVOKE	Remove authority
RECOVER	Roll back, compensate or otherwise manage consequences
RECONSTRUCT	Establish what happened and why
NOTIFY	Escalate internally and externally where required

Exact response times must be defined according to risk and tested.

DEGRADED-MODE DRILLS

Testing should include realistic degradation such as:

- reduced staffing;
- unavailable personnel;
- network failure;
- logging failure;
- authentication failure;
- monitoring failure;
- critical infrastructure failure;
- simultaneous failures.

Drills should:

- be documented;
- measure actual performance;
- compare performance with approved SLAs;
- generate remediation where thresholds are missed;
- be re-tested after material deficiencies.

Independent observation should be used where appropriate to the risk.

AUTOMATED CONTAINMENT

For high-risk agents, automated containment should be the primary mechanism where technically feasible.

It should:

- detect abnormal conditions;
- trigger predefined restrictions;
- suspend material activity when thresholds are breached;
- preserve evidence;
- notify responsible personnel.

Human intervention remains essential for governance decisions, recovery and authorized override.

Overrides must be:

- attributable;
- authorized;
- justified;
- logged;
- retrospectively reviewed.

REVOCABILITY ASSESSMENT

Every material action class must be assessed for:

- reversibility;
- time required;
- dependencies;
- downstream consequences;
- compensating controls;
- recovery limitations.

Irreversible actions require enhanced preventive controls and explicit risk acceptance where appropriate.

THE COMPLETE CONTROL TEST

For every material agentic-AI control, Internal Audit should be able to answer:

1. Is the control objective clearly defined?

Evidence: control objective and risk linkage.

2. Is the control appropriately designed?

Evidence: risk assessment and control design.

3. Is it implemented?

Evidence: configuration, deployment and implementation evidence.

4. Is it technically enforced where prevention is required?

Evidence: controlled production or representative environment testing.

5. Does it operate effectively over the relevant period?

Evidence: monitoring and historical test results.

6. Is it re-evaluated when circumstances materially change?

Evidence: change records, re-testing and drift monitoring.

7. Is sufficient, reliable, relevant and useful evidence available?

Evidence: independent evidence package.

8. Can the organization intervene and investigate?

Evidence: containment, revocation and forensic testing.

9. Is human accountability explicit?

Evidence: named accountability and escalation arrangements.

10. Are third-party dependencies appropriately controlled?

Evidence: due diligence, contractual controls, assurance and monitoring.

11. Is assurance proportionate to the risk and sufficiently continuous?

Evidence: ongoing monitoring, automated testing and periodic independent assurance.

CONTROL RATING

Result	Assessment
Effective	Control objectives are met and evidence supports operating effectiveness
Partially Effective	Control exists but material limitations remain
Ineffective	Control does not adequately address the relevant risk
Not Implemented	Required control does not exist
Not Applicable	Applicability has been documented and independently validated

Every deficiency must identify:

- risk;
- root cause;
- impact;
- owner;
- remediation;
- target date;
- residual risk;
- re-testing requirement;
- escalation requirement.

Critical deficiencies require immediate escalation according to the organization's approved governance and risk framework.

HUMAN ACCOUNTABILITY

The framework establishes a non-transferable principle:

| **AI may execute. Humans remain accountable.**

Requirements include:

- named accountability for material action classes;
- accountable executive for the overall program;
- defined escalation chain;
- appropriate authority and resources;
- documented accountability;
- appropriate training;
- workload limits;
- meaningful human intervention where required.

Human oversight must be **substantive**, not merely ceremonial.

A nominal human who cannot understand, challenge, stop or meaningfully influence the agent is not effective oversight.

THIRD-PARTY AGENTS

Third-party agents must not become governance blind spots.

Organizations should assess:

- vendor governance;
- security;
- agent capabilities;
- material risks;
- boundaries;
- data handling;
- incident response;
- evidence availability;
- change management;
- subcontractors;
- right-to-audit arrangements.

Assurance reports must be assessed for:

- scope;
- period;
- relevance;
- exceptions;
- limitations;
- applicability to the actual service being used.

Third-party assurance does not eliminate the organization's own accountability.

INTERNAL AUDIT AUTHORITY

Internal Audit must retain:

- independence;
- unrestricted access appropriate to its mandate;
- authority to escalate significant deficiencies;
- ability to perform independent testing;
- ability to obtain evidence directly;
- protection against inappropriate management interference.

For critical deficiencies, Internal Audit may **recommend suspension or restriction** to the appropriate governance authority.

The framework does not make Internal Audit the operational owner of the agent.

**Management owns the risk and controls.
Internal Audit independently assesses and reports on them.**

CONTINUOUS ASSURANCE

Where the risk and technology support it:

- control monitoring should operate continuously;
- material control degradation should trigger alerts;
- automated audit procedures may execute continuously;
- audit procedures should be version-controlled;
- automated tests should be independently validated;
- Internal Audit should use continuous data where appropriate.

Continuous assurance does **not** mean Internal Audit assumes management's monitoring responsibilities.

RISK GOVERNANCE

Material agentic-AI risks should be assessed across:

- financial;
- operational;
- regulatory;
- privacy;
- cybersecurity;
- reputational;
- customer;
- strategic;
- concentration;
- third-party;
- systemic/inter-agent risks.

Assessment should consider:

- individual actions;
- cumulative exposure;
- correlated failures;
- simultaneous failures;
- worst-case credible scenarios.

Risk appetite must be:

- approved;
- documented;
- measurable where practical;
- monitored;
- periodically reassessed.

BOARD GOVERNANCE

The governing body should have sufficient understanding to challenge management on:

- purpose;
- risk;
- accountability;
- material exposure;
- control effectiveness;
- incident readiness;
- third-party dependency;
- concentration;
- reversibility;
- residual risk.

Board evidence should demonstrate **substantive consideration**, not merely formal approval.

The exact governance mechanisms—training, advisers, legal counsel, insurance and committee structures—should be determined according to organizational circumstances and applicable requirements.

REGULATORY & POLICY GOVERNANCE

The organization must:

1. identify applicable obligations;
2. map relevant obligations to controls;
3. monitor regulatory changes;
4. assign responsibility;
5. update controls when requirements change;
6. preserve evidence of compliance decisions.

Jurisdiction-specific requirements must be incorporated where applicable.

EMERGING-RISK GOVERNANCE

The organization should maintain:

- horizon scanning;
- emerging-risk assessment;
- scenario analysis;
- framework review;
- threat intelligence;
- technology-change monitoring.

Material emerging risks should trigger reassessment rather than waiting for the annual review cycle.

EVIDENCE COMPLETENESS

Management must not be able to selectively present only favorable evidence.

The assurance process should provide mechanisms for:

- independent evidence collection;
- access to failed tests;
- access to exceptions;
- access to incidents and near misses;
- identification of missing evidence;
- preservation of contradictory evidence.

Evidence of failure is evidence too.

DECOMMISSIONING

An agent is not decommissioned merely because it is removed from the production dashboard.

The organization must address:

- production instances;
- backup instances;
- staging/test instances;
- credentials;
- tokens;
- APIs;
- scheduled jobs;
- integrations;
- downstream dependencies;
- data;
- logs;
- certificates;
- service accounts.

Automated discovery should periodically identify unauthorized or forgotten agents.

A decommissioned agent that retains material authority is a governance failure.

THE GOVERNANCE SHIFT

FROM

TO

Policy document	Codified and enforceable intent
Role-based authority	Attributable, bounded and revocable authority
Detective controls	Prevention where risk requires it
Staging-only testing	Representative operating-condition testing
Periodic testing	Continuous/adaptive assurance where appropriate
Logs	Trustworthy, reconstructable evidence
Private model reasoning	Documented decision rationale
Assumed revocability	Tested revocability
Human-in-the-loop	Meaningful human accountability

Single-agent view	Ecosystem and multi-agent view
Static configuration	Controlled change and behavioral monitoring
Third-party trust	Evidence-based third-party assurance
Point-in-time assessment	Risk-proportionate continuous assurance
Clean-room drills	Realistic degraded-condition testing
Fail-open assumption	Defined safe-state behavior
Implicit permissions	Explicit authorization boundaries
Zombie-agent assumption	Continuous inventory and decommissioning verification

THE ELEVEN FINAL PRINCIPLES

1. **AI executes at machine speed; governance must operate at a speed appropriate to the risk.**
2. **Accountability never transfers to the machine.**
3. **A control that cannot be demonstrated under relevant operating conditions has not been adequately proven.**
4. **A record that can be silently altered cannot be relied upon as trustworthy evidence.**
5. **A successful clean-room drill does not establish real-world readiness.**
6. **A moving system requires assurance that reflects material change and ongoing risk.**
7. **Multi-agent interaction creates risks that cannot always be identified from single-agent testing.**
8. **Material behavioral change requires reassessment.**
9. **Internal Audit must have sufficient authority and access to independently assess critical controls.**
10. **A governing body cannot effectively challenge risks it does not understand.**
11. **“Show me the policy” is insufficient. Show me where the control operates—and demonstrate with evidence that it works.**

THE COMPLETE BOARD QUESTION

If our highest-risk agentic AI system behaved outside its approved boundaries tomorrow at 2:00 AM, could management prove—rather than merely assert—that it was detected, contained, investigated, and governed?

Detection

- When would we know?
- What would detect it?
- What happens if monitoring fails?

Containment

- How quickly can the agent be stopped?
- Can its tools and data access be restricted?
- Can authority be revoked?

Exposure

- What actions occurred?
- What cumulative exposure was created?
- What systems and data were affected?

Evidence

- Can every material action be reconstructed?
- Can the authorization be verified?
- Can the relevant decision rationale and data provenance be established?
- Can evidence integrity be independently demonstrated?

Recovery

- What can be reversed?
- What cannot be reversed?
- What compensating controls exist?
- What is the tested recovery capability?

Accountability

- Who is accountable?
- Who can intervene?
- Who receives escalation?
- Who accepts residual risk?

Third Parties

- Could a vendor or external dependency have caused the failure?
- Can the organization obtain sufficient evidence?
- Can the dependency be contained?

Behavioral Change

- Did the agent materially change?
- Was that change detected?
- Was reassessment triggered?

Multi-Agent Risk

- Could another agent have amplified the event?
- Were delegation and aggregate authority boundaries enforced?

Governance

- Could the organization demonstrate all of this to its governing body, regulator, customer, or other legitimate stakeholder using reliable evidence?

THE I-A-N-E-T-F READINESS TEST

An organization should **not declare a material agent ready for production solely because it has an approved policy or successful pilot.**

Readiness requires evidence that:

Intent is bounded → Authority is attributable → Enforcement is demonstrated → Testing is adaptive → Evidence is trustworthy → Revocation is tested.

If one of these capabilities is materially absent, management should identify the resulting risk, determine whether compensating controls exist, and obtain appropriate risk acceptance before proceeding.

FRAMEWORK STATUS

THE I-A-N-E-T-F FRAMEWORK™

Enterprise Audit & Assurance Framework for Agentic AI

This is an **independent framework** for assessing the governance, risk, control, assurance, evidence, intervention and lifecycle management of agentic AI.

It does not replace:

- applicable law;
- regulation;
- professional standards;
- organizational policy;
- risk appetite;
- management accountability;
- or technical security requirements.

The framework must be tailored to:

- risk;
- materiality;
- system architecture;
- industry;
- jurisdiction;
- agent capability;
- degree of autonomy;
- and potential impact.

Tailoring must not be used to conceal or ignore material risk.

THE CORE TEST

Can management prove that the agent is operating within approved boundaries—not merely state that it is?

And when the answer is **yes**, the auditor should be able to trace that assertion through:

INTENT → AUTHORITY → ENFORCEMENT → TESTING → TRACEABILITY → FORENSICS & REVOCABILITY

with evidence.

The framework's central proposition:

**Declared governance is an assertion.
Enforced governance is demonstrable.
Auditable governance is demonstrable with reliable evidence.**

Anything less should be treated as a governance risk—not automatically as a governance framework.

THE FUTURIST'S STRATEGY CONE™

Reimagining Internal Audit for the Age of Agentic AI



By **Adnan Shamim**

THE FUTURIST'S STRATEGY CONE™

A Human-Controlled Governance Framework
for Agentic AI in Internal Audit

4 STAGES: Risk → Audit → Evidence → Reporting



RISK

Identify, assess and prioritize AI risks across processes and data.



AUDIT

Design and perform intelligent audits with AI oversight and human judgment.



EVIDENCE

Capture immutable, traceable and verifiable audit evidence.



REPORTING

Deliver meaningful insights for assurance and decision-making.



Agentic AI
Audit Leader



Predictive
Intelligence



Real-time
Assurance



Stronger
Governance

ADNAN SHAMIM

AGENTIC AI LEADER

INTERNAL AUDIT & AI GOVERNANCE PROFESSIONAL



EMAIL

ad.shamim1985@gmail.com



MOBILE

03138224669



CREATOR OF
**THE FUTURIST'S
STRATEGY CONE™**



Designed for Boards, CFOs & CAEs
to Govern Agentic AI with Confidence



AI Enhances Capability,
Humans Maintain Accountability.



Explore the
Framework

Scan to
learn more.



ad.shamim1985@gmail.com



03138224669



linkedin.com/in/
adnan-shamim-802a6622b



DM **"CONE"** for Framework